

Manual 53 — Privacidad de IA y Gobernanza de Datos

Fuente controlada de publicación — español latinoamericano

Fecha de verificación: 1 de septiembre de 2026

Estado de liberación: fuente candidata

Propósito

Este manual establece un modelo operativo práctico de privacidad y gobernanza de datos para sistemas de IA, incluyendo aprendizaje automático convencional, IA generativa, RAG/almacenes vectoriales y sistemas agénticos. Está diseñado para apoyar la implementación empresarial sin convertir obligaciones legales específicas de cada jurisdicción en una sola regla genérica de privacidad.

Disciplina sobre el estado de las fuentes

El NIST Privacy Framework es orientación voluntaria. Para esta edición, Privacy Framework 1.1 continúa como proyecto Initial Public Draft y no se presenta como reemplazo final de PF 1.0. Las leyes, guías regulatorias y obligaciones contractuales de cada jurisdicción conservan su propia aplicabilidad, definiciones, derechos, plazos y estado de cumplimiento. Un control empresarial común puede apoyar varios regímenes, pero no los vuelve equivalentes.

Modelo operativo de privacidad y datos

Caso de uso → fuente de datos → autorización/propósito → ingestión → preprocesamiento → entrenamiento/ajuste → límite del modelo/proveedor → prompt/contexto → RAG/almacén vectorial → herramientas/API → salida → registros/telemetría → retención/eliminación → evidencia de derechos/incidentes/cambios.

PD-01 — Uso autorizado y limitación de propósito

Documentar propósito empresarial, base jurídica o autorización aplicable, restricciones de origen, compatibilidad del uso y responsable antes de utilizar datos para entrenamiento, ajuste, RAG, evaluación, monitoreo o inferencia de producción.

PD-02 — Inventario, procedencia y linaje de datos

Mantener inventario trazable de conjuntos de datos, prompts, corpus, embeddings, almacenes vectoriales, datos de retroalimentación, conjuntos de evaluación y datos mantenidos por proveedores. Registrar fuente, propietario, base de adquisición, transformaciones, usos posteriores y restricciones materiales.

PD-03 — Minimización y limitación de recolección

Limitar datos personales, confidenciales y sensibles a lo necesario para el propósito aprobado. Evaluar atributos de menor riesgo, agregación, enmascaramiento, datos sintéticos o menor retención cuando permitan alcanzar el objetivo.

PD-04 — Datos sensibles y categorías especiales

Identificar datos sensibles, de categorías especiales, biométricos, de salud, financieros, ubicación precisa, menores y otros datos protegidos según los regímenes aplicables. Aplicar autorización, acceso, minimización, pruebas y escalamiento reforzados cuando corresponda.

PD-05 — Calidad y representatividad de datos

Definir criterios de aptitud para el propósito, limitaciones conocidas, datos faltantes, sesgo de muestreo, calidad de etiquetas y deriva. Conservar evidencia de que las decisiones de calidad fueron apropiadas para el caso de uso y las poblaciones afectadas.

PD-06 — Gobernanza de datos de entrenamiento y ajuste

Controlar datos de entrenamiento, fine-tuning y retroalimentación mediante fuentes aprobadas, procedencia, revisión de derechos/autorizaciones, versionado, integridad, retención y procedimientos de eliminación. Distinguir configuración de mejora del modelo del proveedor de entrenamiento controlado por la empresa.

PD-07 — Límites de RAG y almacenes vectoriales

Gobernar aprobación del corpus, procedencia documental, embeddings, filtros por rol/tenant, acceso al almacén vectorial, política de recuperación, fuentes obsoletas y propagación de eliminación. Recuperar un documento no demuestra que su uso sea autorizado o correcto.

PD-08 — Autorización de recuperación y aislamiento

Evaluar autorización en el momento de recuperación, no solo durante ingestión. Prevenir recuperación entre tenants, roles o propósitos y probar inyección indirecta y exfiltración iterativa que pueda revelar datos fuera de autorización.

PD-09 — Retención y eliminación

Definir reglas para datos fuente, prompts, salidas, logs, embeddings, almacenes vectoriales, cachés, copias de respaldo y copias del proveedor. Verificar propagación de eliminación y documentar limitaciones técnicas cuando la eliminación inmediata no sea viable.

PD-10 — Transferencias internacionales y residencia

Mapear origen, lugar de procesamiento, cadena de proveedores/subprocesadores, almacenamiento y mecanismo de transferencia cuando aplique. Conservar evaluaciones y salvaguardas específicas por jurisdicción, sin asumir que un control global satisface todos los regímenes.

PD-11 — Soporte de derechos de las personas

Cuando aplique, apoyar acceso, corrección, eliminación, oposición, restricción, apelación u otros derechos. Analizar implicaciones para modelo, entrenamiento, RAG, logs y proveedores y registrar cuándo una solicitud no puede cumplirse técnica o jurídicamente tal como fue formulada.

PD-12 — Transparencia y avisos de privacidad

Proporcionar avisos exactos sobre usos relevantes de datos, procesamiento de IA, proveedores, retención, decisiones automatizadas o apoyadas por IA y opciones materiales cuando sea requerido. No afirmar que todo uso de IA exige el mismo mecanismo de aviso o consentimiento.

PD-13 — Integración de DPIA/PIA

Aplicar evaluación de impacto de privacidad cuando sea requerida o adecuada al riesgo. Documentar personas afectadas, necesidad/proporcionalidad cuando corresponda, flujos de datos, amenazas, mitigaciones, riesgo residual, consultas, aprobaciones y disparadores de reevaluación.

PD-14 — Integración con evaluación de impacto/riesgo de IA

Compartir evidencia entre evaluaciones de privacidad y riesgo de IA manteniendo criterios de decisión separados. Relacionar daños de privacidad, equidad, amenazas de seguridad, supervisión humana, explicabilidad e impactos operativos sin sustituir una evaluación por otra.

PD-15 — Desidentificación y riesgo de reidentificación

Validar afirmaciones de anonimización, desidentificación, seudonimización o agregación frente a riesgos realistas de enlace e inferencia. No considerar datos transformados automáticamente fuera del alcance de privacidad sin análisis jurídico y técnico sustentable.

PD-16 — Registro y observabilidad con preservación de privacidad

Recolectar telemetría suficiente para seguridad, calidad y responsabilidad minimizando contenido personal o sensible innecesario. Definir redacción, acceso, retención, identificadores de correlación y reglas de preservación para incidentes.

PD-17 — Gobernanza de datos de terceros y proveedores de modelos

Evaluar roles del proveedor, uso de prompts/salidas, mejora del modelo, subprocesadores, alojamiento, retención, seguridad, incidentes, evidencia de auditoría, transferencias y requisitos de salida/eliminación. Reconciliar contratos con la configuración técnica real.

PD-18 — Incidentes y brechas de privacidad

Preservar datos, personas, sistemas, versiones de modelo/proveedor, prompts, eventos RAG, identidades y evidencia de contención. Realizar análisis de notificación específico por jurisdicción e integrar incidentes de privacidad con respuesta de seguridad e IA.

PD-19 — Gestión de cambios y reevaluación

Disparar reevaluación ante nuevas fuentes, propósitos, jurisdicciones, modelos/proveedores, corpus RAG, herramientas, permisos, configuraciones de retención o cambios materiales del procesamiento. Registrar aprobación, pruebas y disposición del riesgo residual.

PD-20 — Aseguramiento, auditoría y reporte gerencial

Probar evidencia de implementación, flujos de derechos, eliminación, límites de recuperación, controles de proveedor, calidad de evaluaciones y excepciones. Reportar riesgos residuales materiales, remediaciones vencidas, incidentes, problemas de transferencia y fallas recurrentes.

Escenarios prácticos

Escenario 1 — Asistente GenAI global con RAG interno

Rastrear procedencia documental, sensibilidad de datos, límites de acceso, retención de embeddings/vector, restricciones de entrenamiento del proveedor, alojamiento internacional, propagación de eliminación y logs de recuperación. Separar evidencia empresarial común de obligaciones específicas por jurisdicción.

Escenario 2 — Modelo entrenado con datos históricos de clientes

Validar propósito original, autorización, minimización, datos sensibles, retención, representatividad, afirmaciones de desidentificación y riesgos posteriores. Determinar si se requiere reentrenamiento, exclusión o eliminación por retiro de fuente o ejercicio de derechos.

Escenario 3 — Decisión laboral apoyada por IA

Combinar análisis de privacidad/laboral, evaluación de impacto de IA, minimización, atributos sensibles o inferidos, revisión humana, explicación/apelación, retención y responsabilidad del proveedor.

Escenario 4 — Proveedor externo de modelo fundacional

Documentar rol del proveedor cuando aplique, uso de prompts/salidas, subprocesadores, alojamiento, retención, seguridad, incidentes, mejora del modelo y requisitos de salida/eliminación.

Escenario 5 — Nueva jurisdicción después del despliegue

Activar revisión de aplicabilidad, transferencias, avisos/derechos, retención local, ubicación del proveedor y nueva aprobación antes de ampliar el uso cuando corresponda.

Registro de evidencia

- PD-E01 Inventario de datos de IA.
- PD-E02 Registro de procedencia y linaje.
- PD-E03 Evaluación de uso autorizado y propósito.
- PD-E04 DPIA/PIA y evaluación de impacto de IA.
- PD-E05 Registro de controles de datos sensibles.
- PD-E06 Registro de gobernanza RAG/vector.
- PD-E07 Evidencia de respuesta a derechos.
- PD-E08 Evaluación de transferencia internacional.
- PD-E09 Evaluación de datos de terceros.
- PD-E10 Verificación de retención/eliminación.
- PD-E11 Registro de incidente de privacidad.
- PD-E12 Registro de cambio/reevaluación.

Regla de liberación

Un control de privacidad no es efectivo solo porque exista una política. La efectividad requiere evidencia de implementación, aplicabilidad calificada por jurisdicción, pruebas, manejo de excepciones y disposición del riesgo residual. Cambios legales, técnicos o de proveedor materiales requieren reevaluación.